

外部委託管理規程

文書管理

本規程は「外部委託管理規程」(文書番号: OP-SEC-031)として管理される。現行バージョンは3.1であり、2024年4月1日付でコンプライアンス部長の承認を得て制定された。本規程の管理責任者はコンプライアンス部 規程管理課長とし、年次および重大な環境変化時に見直しを実施する。

改訂履歴は文書管理システム (DocManager) にて一元管理し、過去の全バージョンを5年間保持する。改訂時には、関連部署 (情報システム部、リスク管理部、法務部) への事前照会を必須とし、コンプライアンス委員会での審議を経て承認するものとする。

本規程の周知は、制定・改訂の都度、全社ポータルサイトへの掲載および関係部署への通知メールにより行う。外部委託業務に従事する全職員は、本規程の内容を理解し遵守する義務を負う。理解度確認のため、年1回のeラーニング受講を必須とする。

目的と適用範囲

本規程は、当行が外部委託を行うにあたり、委託業務に伴うリスクを適切に管理し、顧客情報および銀行業務の安全性・信頼性を確保することを目的とする。金融情報システムセンター (FISC) の「金融機関等コンピュータシステムの安全対策基準・解説書」における運用基準 運-23 (外部委託先の選定・管理) および運-24 (外部委託に係るリスク管理) に準拠する。

本規程は、当行が第三者に委託するシステム開発、システム運用・保守、データセンター運営、BPO (ビジネス・プロセス・アウトソーシング)、クラウドサービス利用、およびその他情報資産の取扱いを伴う一切の外部委託に適用される。ただし、単純な物品購入や一般的な施設管理業務は本規程の対象外とする。

本規程の適用対象には、グループ会社への委託も含まれる。グループ会社への委託であっても、業務の重要度に応じたリスク評価および契約締結を省略してはならない。海外拠点における外部委託については、現地法令を踏まえた上で本規程の趣旨に沿った管理を行うものとする。

委託先選定基準

外部委託先の選定にあたっては、当行が定めるセキュリティ評価チェックリスト (全50項目) に基づく評価を実施する。チェックリストは、情報セキュリティ管理体制 (15項目)、物理的セキュリティ (10項目)、技術的セキュリティ (15項目)、人的セキュリティ (10項目) の4カテゴリで構成される。重要度分類Aの業務については、50項目中45項目以上の適合を必須要件とする。

財務健全性の評価として、直近3期分の財務諸表の分析を行い、自己資本比率、流動比率、営業利益率等の指標が当行の定める基準値を満たすことを確認する。ISMS認証 (ISO/IEC 27001) の取得を推奨要件とし、重要度分類Aの業務においては必須要件とする。プライバシーマーク (Pマーク) の取得状況も評価項目に含める。

委託先候補の過去3年間におけるセキュリティインシデント発生歴を確認し、重大インシデント (情報漏洩、サービス長期停止等) の発生実績がある場合は、再発防止策の実効性を慎重に評価した上で選定の可否を判断する。選定評価結果は情報セキュリティ委員会に報告し、重要度分類Aの委託先選定については同委員会の承認を得る。

複数の候補先がある場合は、技術力、コスト、実績、事業継続性を総合的に評価し、スコアリングモデルに基づく比較評価を実施する。特定の委託先への過度な依存を回避するため、集中リスクの観点からも評価を行う。

リスク評価

委託業務は、取り扱う情報資産の機密性・完全性・可用性への影響度に基づき、重要度分類A（極めて重要）、B（重要）、C（一般）の3段階に分類する。重要度分類Aは、基幹系システムの開発・運用、顧客個人情報的大量処理、決済系システムに関わる業務等が該当する。

リスク評価は、委託業務ごとに「外部委託リスク評価シート」を用いて実施する。評価項目は、情報漏洩リスク、業務中断リスク、法令違反リスク、レピュテーションリスクの4軸とし、それぞれ発生可能性と影響度のマトリクスで評価する。残留リスクが当行のリスク許容水準を超える場合は、追加の管理策を講じるか、委託の可否を再検討する。

リスク評価は年次で見直しを行い、委託先の体制変更、セキュリティインシデントの発生、法令改正等の環境変化があった場合には臨時の再評価を実施する。評価結果はリスク管理部に報告し、全社リスク管理の枠組みの中で統合的に管理する。

契約要件

外部委託契約には、以下の条項を必ず含めるものとする。秘密保持条項（NDA）は、委託期間中および契約終了後5年間の秘密保持義務を規定する。セキュリティ要件は別紙として詳細を定め、契約本体と一体の文書として取り扱う。

SLA（サービスレベル合意書）では、可用性（稼働率99.9%以上等）、応答時間、障害復旧時間（RTO/RPO）、処理性能等の定量的な基準を明記する。インシデント発生時の通知義務として、委託先はセキュリティインシデントを検知した場合、24時間以内に当行の情報セキュリティ管理責任者に報告しなければならない。重大インシデントについては、第一報を検知後2時間以内に行うものとする。

当行による監査権を契約に明記し、定期監査および随時監査を実施できる権限を確保する。損害賠償条項では、委託先の責に帰すべき情報漏洩等が発生した場合の賠償範囲および上限を定める。契約解除条件として、重大なセキュリティ違反、SLA基準の継続的な未達成、財務状況の著しい悪化等を明記し、即時解除が可能な条件を具体的に規定する。

契約書のひな型は法務部が管理し、業務内容に応じて必要な条項を追加する。契約締結前には法務部による法的レビューを必須とし、重要度分類Aの契約については外部弁護士によるレビューも実施する。

セキュリティ要件

委託先における当行データの取扱い場所は、原則として日本国内に限定する。海外でのデータ取扱いが不可避な場合は、情報セキュリティ委員会の事前承認を得た上で、当該国のデータ保護法制を確認し、追加的な保護措置を講じるものとする。クラウドサービスのリージョン選択においても、本基準を適用する。

アクセス制御については、当行データへのアクセスは業務上必要な最小限の権限に限定し、特権アカウントの使用は承認制とする。多要素認証（MFA）の導入を必須とし、アクセスログは最低1

年間保持する。委託先からのリモートアクセスには、当行指定のVPN経由でのアクセスのみを許可する。

データの暗号化については、保管時 (at rest) はAES-256以上、転送時 (in transit) はTLS 1.2以上の暗号化を必須とする。暗号鍵の管理は当行が主体的に行い、委託先に暗号鍵を単独で管理させてはならない。

操作ログおよびアクセスログの取得は必須とし、委託先は当行の求めに応じてログを速やかに提出する義務を負う。ログのフォーマットは当行指定の形式に準拠し、改ざん防止措置を講じた上で保管するものとする。

監督・モニタリング

委託先に対する監督は、日常的なモニタリングと定期的な評価の二層構造で実施する。日常モニタリングとして、委託先から四半期ごとに業務報告書の提出を受け、SLA達成状況、インシデント発生状況、要員体制の変更等を確認する。報告書の様式は当行が指定し、定量データと定性コメントの両方を求める。

年次立入監査は、重要度分類Aの委託先に対して毎年必ず実施する。重要度分類Bの委託先は2年に1回以上、重要度分類Cの委託先は3年に1回以上実施する。監査は情報セキュリティ部門の監査員が実施し、必要に応じて外部の専門機関を活用する。監査結果は情報セキュリティ委員会に報告し、重大な指摘事項がある場合は経営会議にもエスカレーションする。

KPIモニタリングでは、以下の指標を継続的に測定・管理する。SLA達成率 (目標: 99%以上)、セキュリティインシデント件数 (目標: 0件)、セキュリティパッチ適用率 (目標: 適用期限内100%)、従業員教育実施率 (目標: 100%)。KPIが基準値を下回った場合は、委託先に改善計画の提出を求め、改善状況をフォローアップする。

再委託管理

委託先が業務の全部または一部を第三者に再委託する場合は、当行の事前承認を必須とする。再委託の申請には、再委託先の概要、再委託の理由、再委託する業務範囲、セキュリティ管理体制等を記載した申請書の提出を求める。重要度分類Aの業務については、原則として再委託を認めない。

再委託を承認する場合、当行が委託先に課しているセキュリティ要件と同等以上の要件を再委託先にも適用するよう、委託先に義務づける (セキュリティ要件の流下義務)。委託先は再委託先に対して適切な監督を行い、その状況を当行に報告する義務を負う。

再委託先の評価は、委託先の選定基準に準じた基準で委託先が実施し、評価結果を当行に提出するものとする。当行は必要に応じて再委託先への直接監査を実施する権限を有する。再委託チェーンの多層化を防止するため、再々委託 (再委託先からのさらなる委託) は原則禁止とする。

契約終了時措置

外部委託契約の終了時 (満了、解除を問わない) には、以下の措置を確実に実施する。委託先が保有する当行データは、契約終了後30日以内に当行への返却または復元不可能な方法での消去を完了させる。消去完了後、委託先から「データ消去証明書」の提出を受ける。消去方法は、NIST SP 800-88に準拠した媒体サニタイズを基準とする。

委託先に付与していた当行システムへのアクセス権限（アカウント、VPN接続権限、物理入館権限等）は、契約終了日をもって即日無効化する。アカウント無効化の実施確認は情報システム部が行い、完了報告を情報セキュリティ管理責任者に提出する。

業務の移行（他の委託先への切替えまたは内製化）が伴う場合、委託先は合理的な範囲で移行支援を提供する義務を負う。移行支援期間は原則として契約終了前3か月間とし、移行計画の策定、技術情報の引継ぎ、並行稼働期間の運用支援を含む。移行支援の具体的な内容と費用は、契約時に予め合意しておくものとする。